

Web Server Compromise Investigation and Network Traffic Analysis

Project Overview

This project documents the investigation of a compromised web server following a brute-force attack against an administrative account. The attacker gained unauthorized access by successfully guessing a default administrator password, modified the website's source code, and inserted malicious JavaScript designed to prompt visitors to download and execute a malicious file.

The investigation focused on analyzing the sequence of the attack, identifying the network protocols involved, reviewing suspicious network activity observed with tcpdump, determining the root cause of the compromise, and recommending security controls to reduce the risk of similar attacks.

Incident Scenario

A web application was compromised after an attacker performed a brute-force attack against the website's administrative account. The attacker repeatedly attempted known default passwords until the correct credentials were identified.

After gaining administrative access, the attacker modified the website's source code and embedded malicious JavaScript. When users visited the compromised website, they were prompted to download and execute a file presented as a browser update.

After execution, affected users were redirected from the legitimate website to a malicious domain. Several users later reported degraded system performance after running the downloaded file.

The legitimate website owner was also unable to access the administrative panel because the attacker had changed the administrator password after gaining control of the account.

Investigation Process

The incident was investigated in a controlled sandbox environment to safely observe the behavior of the compromised website.

Network traffic was examined using tcpdump while accessing the affected website. During the investigation, the browser loaded the legitimate domain and displayed a prompt requesting the download of an executable file. After the file was executed in

the controlled environment, the browser was redirected to a different domain associated with malicious activity.

The investigation identified the following sequence of network activity:

1. The browser initiated a DNS request to resolve the legitimate website domain.
2. The DNS server returned the corresponding IP address.
3. The browser initiated an HTTP request to the web server.
4. The compromised website triggered the download of a malicious executable file.
5. Additional DNS activity occurred as part of the malicious redirection process.
6. The browser resolved the attacker-controlled domain.
7. An HTTP request was made to the malicious website.

This network activity demonstrated how DNS and HTTP traffic were involved in accessing the compromised website and completing the malicious redirection chain.

Network Protocol Analysis

DNS — Domain Name System

DNS was used to translate domain names into IP addresses so the browser could locate and communicate with the corresponding web servers.

During the incident investigation, DNS traffic was observed when accessing the legitimate website and later when the browser attempted to connect to the attacker-controlled domain.

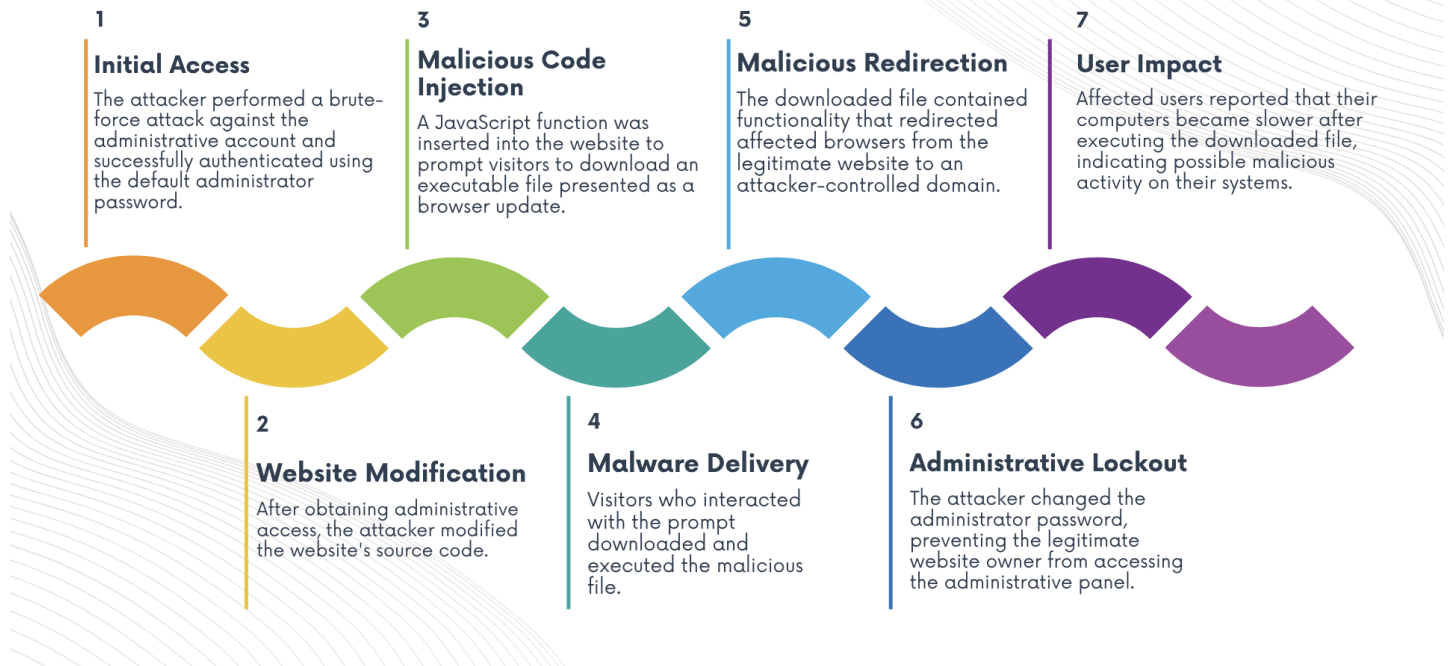
HTTP — Hypertext Transfer Protocol

HTTP was used for communication between the browser and the web servers.

The protocol was involved in loading the compromised website, delivering web content, initiating the malicious file download, and communicating with the malicious destination after the redirection process.

The combination of DNS resolution and HTTP communication helped reconstruct the sequence of network events associated with the incident.

ATTACK TIMELINE



Indicators and Evidence

The investigation identified several indicators associated with the incident:

- Repeated authentication attempts against the administrative account.
- Successful access using a default administrator password.
- Unauthorized modification of the website's source code.
- Injection of malicious JavaScript.
- Unexpected prompt requesting users to download an executable file.
- Execution of a suspicious downloaded file.
- Redirection from the legitimate website to an attacker-controlled domain.

- Unexpected DNS and HTTP traffic associated with the redirection process.
- Loss of administrative access after the attacker changed the account password.
- Reports of degraded performance on affected user devices.

Root Cause Analysis

The primary root cause of the incident was the continued use of a default password on the administrative account.

The absence of effective protections against repeated authentication attempts allowed the attacker to perform a brute-force attack until the correct password was identified.

Once authenticated, the attacker had sufficient privileges to modify the website's source code, insert malicious JavaScript, distribute a malicious executable, and change the administrator password.

Security Remediation

The primary recommended security control is the implementation of Multi-Factor Authentication (MFA) for administrative accounts.

MFA requires an additional verification factor beyond a password. Even if an attacker successfully obtains or guesses the administrator password, access to the administrative panel would still require the additional authentication factor.

Additional defensive measures that could strengthen the authentication process include eliminating default passwords, enforcing strong password policies, implementing account lockout thresholds, and applying rate limiting to repeated login attempts.

Security Impact

The incident affected multiple areas of security:

Confidentiality: Users who executed the malicious file may have exposed information stored on their systems.

Integrity: The attacker modified the legitimate website's source code and inserted unauthorized JavaScript.

Availability: The legitimate administrator lost access to the administrative panel after the attacker changed the account password.

The incident also created reputational risk because users received malicious content through a legitimate website they trusted.

Skills Demonstrated

- Network Traffic Analysis using tcpdump
- DNS and HTTP Traffic Analysis
- Incident Investigation
- Web Server Compromise Analysis
- Brute-Force Attack Analysis
- Malware Delivery Chain Analysis
- Root Cause Analysis
- Security Remediation Planning
- Incident Documentation

Conclusion

This investigation demonstrated how weak administrative credentials and insufficient authentication controls can lead to a complete website compromise.

By analyzing the attack sequence and reviewing DNS and HTTP network activity, the incident could be reconstructed from initial unauthorized access through website modification, malware delivery, malicious redirection, and user impact.

The project reinforced the importance of securing privileged accounts, removing default credentials, implementing Multi-Factor Authentication, and monitoring authentication and network activity for indicators of compromise.